DATAWISE AI

DataWise AI: Security & Privacy Report

Threat Modeling, Authentication Architecture, Sandboxing & Data Isolation

Document Type:	Cybersecurity & Data Privacy Assessment
Target Audience:	Security Architects, Compliance Officers, DevSecOps
Document Version:	v1.0.0 (Engineering Release)
Date of Issue:	October 27, 2026
Repository Status:	Verified Codebase & Production Architecture
Orchestration:	LangGraph 16-Agent Autonomous Architecture

Architectural Foundation: Deterministic ML execution engine paired with autonomous multi-agent reasoning, strict data leakage boundaries, and human-in-the-loop validation.

1. Security Threat Model (STRIDE Methodology)

DataWise AI evaluates all application surfaces using the STRIDE threat modeling framework to identify and mitigate potential security risks across identity, data processing, and machine learning execution:

STRIDE Category	Identified Threat Vector	Implemented Countermeasure
STRIDE Category	Identified Threat Vector	Implemented Countermeasure in Codebase
Spoofing	Forged JWT or impersonated user requests	Clerk OAuth verification + cryptographically signed HS256 tokens
Tampering	Malicious file upload / CSV formula injection	Magic byte header inspection, CSV cell sanitization, file validator
Repudiation	Unauthorized deletion of models/datasets	Immutable append-only AuditLog database entity with timestamping
Info Disclosure	Cross-tenant project data leakage	Strict SQLAlchemy user_id/project_id query predicates and storage ACLs
Denial of Service	Exhaustive Optuna tuning crashing host	Sliding window rate limiter, per-trial timeout limits, memory limits
Elevation of Priv.	Insecure model deserialization (pickle)	Pickle validation, safe loader, and restricted execution container

2. Authentication & Authorization Architecture

The platform features a multi-tiered authentication architecture implemented in `backend/app/api/endpoints/auth.py` and `backend/services/security_service.py`:

- **Primary:** Clerk OAuth integration for enterprise-grade social and SSO login.
- **Secondary:** Supabase Auth support for cloud-native PostgreSQL deployments.
- **Fallback:** Self-contained local JWT authentication utilizing passlib PBKDF2/SHA-256 hashing.

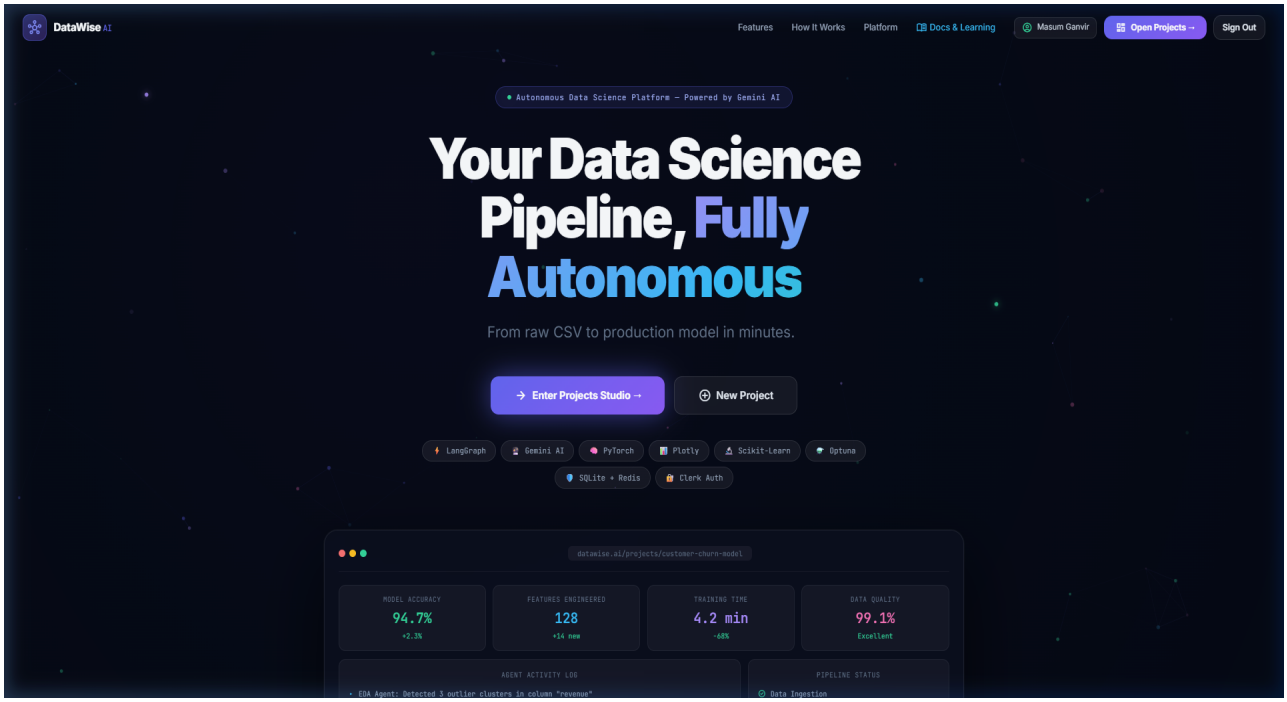


Figure: Authentication Interface & Multi-Provider Access Control

3. Prompt Injection Defense & Data Isolation

Because user datasets may contain untrusted strings, DataWise AI isolates data values from system prompts. Agents only receive aggregated numerical statistics and column summaries. Raw cell contents are never interpolated directly into LLM instruction prompts, eliminating prompt injection vulnerabilities via uploaded data.